

Assignment 2

Problem 1 (25 marks)

Schnorr 签名算法中, Signer 对于两条消息使用统一随机数 r 进行签名是否安全?

不安全: $PK = (G, p, g, h = g^s)$, $SK = s$, 对于消息 M_1 和 M_2 , 如果 Signer 使用同一个随机数 r 进行签名, 则 $\sigma_1 = (R = g^r, z_1)$, $\sigma_2 = (R = g^r, z_2)$ 。攻击者可以通过以下步骤恢复出 Signer 的私钥 s :

1. 计算 $e_1 = H(M_1, R)$ 和 $e_2 = H(M_2, R)$ 。
2. 由于 $z_1 = r + e_1 s$ 和 $z_2 = r + e_2 s$, 可以得到 $z_1 - z_2 = (e_1 - e_2)s$ 。
3. 从而可以计算出 $s = (z_1 - z_2)(e_1 - e_2)^{-1}$ 。

Problem 2 (25 marks)

若变体 DSA 签名算法中省略了 H 的使用, 证明其不安全。

证明: 构造一个攻击者 $\mathcal{A}$, 输入为公钥 $PK = (G, p, g, h = g^s)$, 目标是在多项式次签名查询后, 成功伪造一个未查询消息 M^* 的签名 $\sigma^* = (d^*, z^*)$ 。攻击者 $\mathcal{A}$ 的攻击步骤如下:

1. 随就选择 $\alpha, \beta \leftarrow \mathbb{Z}_p$, 构造 $R = g^\alpha \cdot h^\beta$
2. 计算 $d^* = F(R)$
3. 为了通过验证算法, 即 $R = (g^{M^*} \cdot h^{d^*})^{z^{*-1}} = g^{M^* z^{*-1}} \cdot h^{d^* z^{*-1}}$, 可以让对应指数相等, 即

$$\begin{cases} \alpha = M^* z^{*-1} \\ \beta = d^* z^{*-1} \end{cases}$$

4. 解得:

$$\begin{cases} z^* = d^* \beta^{-1} \\ M^* = \alpha \beta^{-1} d^* \end{cases}$$

5. 则 $\mathcal{A}$ 输出未查询消息 $M^* = \alpha \beta^{-1} d^*$ 和签名 $\sigma^* = (d^*, z^*) = (d^*, d^* \beta^{-1})$ 。
6. 验证攻击可行性:

$$\begin{aligned}
R' &= (g^{M^*} \cdot h^{d^*})^{z^{*-1}} \\
&= g^{\alpha\beta^{-1}d^*(d^*\beta^{-1})^{-1}} \cdot h^{d^*(d^*\beta^{-1})^{-1}} \\
&= g^\alpha \cdot h^\beta \\
\therefore F(R') &= F(R) = d^*
\end{aligned}$$

Problem 3 (25 marks)

证明 DL 问题困难 $\implies$ DSA 身份证明协议是 UI-PA 安全的。

证明：安全性归约，由攻破 UI-PA 安全性的敌手 $\mathcal{A}$ 来构造解决 DL 问题的敌手 $\mathcal{B}$ 。

- 假设 DSA 身份证明协议不是 UI-PA 安全的，即存在 PPT 敌手 $\mathcal{A}$ 以不可忽略的概率攻破 DSA 身份证明协议的 UI-PA 安全性，即

$$\text{Adv}_{\mathcal{A}} = \Pr \left(\text{output} = (R^*, e^*, d^*, z^*) \mid R^* = (g^{e^*} \cdot h^{d^*})^{z^{*-1}} \right) = \text{non-negl}(\lambda)$$

- 构造一个 PPT 敌手 $\mathcal{B}$ 解决 DL 问题。
 - $\mathcal{B}$ 的策略：Rewind 技术
 - $\mathcal{B}$ 将 DL 问题的输入 $PK = (G, p, g, h)$ 作为 DSA 身份证明协议的公钥提供给 $\mathcal{A}$
 - 对于 $\mathcal{A}$ 的每一次协议运行查询， $\mathcal{B}$ 随机选取 $e_i, d_i, z_i \leftarrow \mathbb{Z}_p$ ，计算 $R_i = (g^{e_i} \cdot h^{d_i})^{z_i^{-1}}$ ，为 $\mathcal{A}$ 提供完美模拟的合法四元组 (R_i, e_i, d_i, z_i)
 - 第一次调用：** $\mathcal{B}$ 调用 $\mathcal{A}$ 直到 $\mathcal{A}$ 输出 R^* 时， $\mathcal{B}$ 均匀随机选择 $e_1^*, d_1^* \leftarrow \mathbb{Z}_p$ 作为挑战发送给 $\mathcal{A}$ ，并收到 $\mathcal{A}$ 的应答输出 z_1^*
 - 第二次调用：** $\mathcal{B}$ 再次调用 $\mathcal{A}$ ，所有使用的随机数（包括 $\mathcal{A}$ 内部的随机数和 $\mathcal{B}$ 模拟查询的随机数）均与第一次调用**完全相同**。因此 $\mathcal{A}$ 会再次输出同样的 R^* 。此时 $\mathcal{B}$ 使用**不同的**随机数均匀选择一个新的挑战 $e_2^*, d_2^* \leftarrow \mathbb{Z}_p$ 发送给 $\mathcal{A}$ ，并收到 $\mathcal{A}$ 的应答输出 z_2^* 。
 - 解 DL：**如果两次调用 $\mathcal{A}$ 都成功伪造，则有：

$$\begin{cases} R^* = (g^{e_1^*} \cdot h^{d_1^*})^{z_1^{*-1}} \\ R^* = (g^{e_2^*} \cdot h^{d_2^*})^{z_2^{*-1}} \end{cases}$$

若 $e_1^* \neq e_2^*$ ，两式相除消去 R^* 可得 $1 = g^{e_1^* z_1^{*-1} - e_2^* z_2^{*-1}} \cdot h^{d_1^* z_1^{*-1} - d_2^* z_2^{*-1}}$ ，代入 $h = g^s$ 可得

$$1 = g^{(e_1^* z_1^{*-1} - e_2^* z_2^{*-1}) + s(d_1^* z_1^{*-1} - d_2^* z_2^{*-1})} \implies s = \frac{e_2^* z_2^{*-1} - e_1^* z_1^{*-1}}{d_1^* z_1^{*-1} - d_2^* z_2^{*-1}} = \frac{e_2^* z_1^* - e_1^* z_2^*}{d_1^* z_2^* - d_2^* z_1^*}$$

- $\mathcal{B}$ 的优势: $\mathcal{B}$ 成功解出 s 的概率至少为 $\Pr(\text{两次调用成功且 } e_1^* \neq e_2^*)$, 由于 e_1^* 和 e_2^* 是独立均匀随机选择的, 因此 $\Pr(e_1^* = e_2^*) = \frac{1}{p}$, 从而 $\Pr(e_1^* \neq e_2^*) = 1 - \frac{1}{p}$ 。因此 $\mathcal{B}$ 的优势为:

$$\begin{aligned} \text{Adv}_{\mathcal{B}} &\geq \Pr(\text{两次调用成功且 } e_1^* \neq e_2^*) \\ &= \Pr(\text{两次调用成功}) \cdot \Pr(e_1^* \neq e_2^*) \\ &\geq \text{Adv}_{\mathcal{A}} \cdot \left(1 - \frac{1}{p}\right) \\ &= \text{non-negl}(\lambda) \end{aligned}$$

- 因此, $\mathcal{B}$ 以不可忽略的概率成功解决 DL 问题, 与 DL 问题困难的假设矛盾。得证!

Problem 4 (25 marks)

证明 DSA 身份认证协议满足 UI-PA 安全性 + H, F 为 RO $\implies$ DSA 签名算法满足 EUF-CMA 安全性。

证明: 安全性归约, 由攻破 DSA 签名算法的 EUF-CMA 安全性的敌手 $\mathcal{A}$ 来构造攻破 DSA 身份认证协议的 UI-PA 安全性的敌手 $\mathcal{B}$ 。

- 假设 DSA 签名算法不是 EUF-CMA 安全的, 即存在 PPT 敌手 $\mathcal{A}$ 以不可忽略的概率攻破 DSA 签名算法的 EUF-CMA 安全性, 即 $\mathcal{A}$ 通过若干次签名查询后, 可以输出一个未查询过的消息 M^* 以及一个有效签名 $\sigma^* = (d^*, z^*)$, 以不可忽略的概率满足 $d^* = F(R^*)$, 其中 $R^* = (g^{e^*} \cdot h^{d^*})^{z^{*-1}}$, $e^* = H(M^*)$ 。
- 构造一个 PPT 敌手 $\mathcal{B}$, 在 UI-PA 安全模型下攻破 DSA 身份证明协议。
 - $\mathcal{B}$ 的策略:
 - $\mathcal{B}$ 将从身份认证挑战者 E_{id} 处获得的公钥 $PK = h$ 作为输入提供给 $\mathcal{A}$; 设 $\mathcal{A}$ 进行的 H 预言机查询次数为 $Q_H(\lambda)$, F 预言机查询次数为 $Q_F(\lambda)$ 。
 - $\mathcal{B}$ 随机选择 $i \in [1, Q_H(\lambda)]$ 和 $j \in [1, Q_F(\lambda)]$, 赌 $\mathcal{A}$ 最终伪造的消息 M^* 是第 i 次 H 查询的消息 M_i , 且对应的 R^* 是第 j 次 F 查询的输入 R_j 。同时假设 $\mathcal{A}$ 的查询顺序是先查询 $F(R_j)$ 后查询 $H(M_i)$ 。
 - 当 $\mathcal{A}$ 使用 M_k 进行**签名查询**时: $\mathcal{B}$ 由于本身不具备私钥 SK , 无法生成合法的签名, 因此向挑战者 E_{id} 发起查询, 拿到一组合法记录 (R_k, e_k, d_k, z_k) 。 $\mathcal{B}$ 将签名 $\sigma_k = (d_k, z_k)$ 返回给 $\mathcal{A}$, 并自身记录 $H(M_k) = e_k$ 和 $F(R_k) = d_k$ 。
 - 此时若 $\mathcal{A}$ 要对该签名进行内部验证, 计算时需要用到 H 和 F 的结果, 只能向 $\mathcal{B}$ 模拟的预言机查询, 必然能完美通过检验。
 - 当 $\mathcal{A}$ 使用 M_k 进行第 k 次**哈希 H 查询**时:

- 若 $k = i$ 且 $M_i \notin \{M_x\}$, 即 $\mathcal{A}$ 查到了 $\mathcal{B}$ 赌定的目标承诺 M_i 。则 $\mathcal{B}$ 将 M_i 发送给 E_{id} 作为输入, 得到 E_{id} 返回的随机挑战 (e_{chal}, d_{chal}) , 并把返回的 e_{chal} 当作 $H(M_i)$ 的输出返回给 $\mathcal{A}$ 并记录, 同时暂存 d_{chal} , 留待后用。
- 若 $k = i$ 但 $M_i \in \{M_x\}$, 则重新随机选择一个新的 M_i 进行赌定
- 若 $k \neq i$, $\mathcal{B}$ 查询是否有 $H(M_k)$ 的记录: 有则直接返回; 没有则随机选择 $e \leftarrow \mathbb{Z}_p$ 返回并记录 $H(M_k) = e$ 。
- 当 $\mathcal{A}$ 使用 R_k 进行第 k 次**哈希 F 查询**时:
 - 若 $k = j$, $\mathcal{B}$ 检查是否已经从 E_{id} 获得了暂存的挑战 d_{chal} 。若有则将 d_{chal} 当作 $F(R_j)$ 的输出返回给 $\mathcal{A}$ 并记录; 如果还未获得, 则 $\mathcal{B}$ 直接中止并视为模拟失败。
 - 若 $k \neq j$, $\mathcal{B}$ 查询是否有 $F(R_k)$ 的记录: 有则直接返回; 没有则随机选择 $d \leftarrow \mathbb{Z}_p$ 返回并记录 $F(R_k) = d$ 。
- 最终当 $\mathcal{A}$ 输出伪造签名 $(M^*, \sigma^* = (d^*, z^*))$ 时, 若 $M^* = M_i$ 且计算得出的 $R^* = (g^{e_{chal}} \cdot h^{d_{chal}})^{(z^*)^{-1}} = R_j$, 这意味着 $\mathcal{A}$ 成功使得 $R_j = (g^{e_{chal}} \cdot h^{d_{chal}})^{(z^*)^{-1}}$ 成立, 则 $\mathcal{B}$ 将 z^* 作为自己对 E_{id} 的输出。

○ $\mathcal{B}$ 的优势:

$$\begin{aligned}
 \text{Adv}_{\mathcal{B}} &\geq \Pr \left[\begin{array}{l} (1) \mathcal{A} \text{ 成功攻破 DSA 签名算法的 EUF-CMA 安全性} \\ (2) \mathcal{A} \text{ 查询过 } R^* \text{ 的 } F \text{ 值和 } M^* \text{ 的 } H \text{ 值} \\ (3) \mathcal{B} \text{ 赌对了 } i \text{ 和 } j \text{ (即 } M^* = M_i, R^* = R_j) \\ (4) \mathcal{A} \text{ 的查询顺序满足要求 (即先查 } H \text{ 后查 } F) \end{array} \right] \\
 &\geq \text{non-negl}(\lambda) \cdot \text{non-negl}(\lambda) \cdot \frac{1}{Q_H(\lambda) \cdot Q_F(\lambda)} \cdot \frac{1}{2} \\
 &= \text{non-negl}(\lambda)
 \end{aligned}$$

- 因此, $\mathcal{B}$ 以不可忽略的概率成功冒充了 Prover, 攻破了 DSA 身份证明协议的 UI-PA 安全性, 这与大前提 (DSA 身份认证方案是 UI-PA 安全的) 相矛盾, 得证!